

물리적 취약점 분석



학습내용

- 물리적 보호구역
- 시스템 보호
- 사무실 보안

학습목표

- 물리적 보호구역을 설정할 수 있다.
- 시스템 보호를 위한 케이블 관리 및 시스템 배치를 수행할 수 있다.
- 사무실 보안의 정보보호 정책을 실제 업무환경에 적용할 수 있다.



물리적 보호구역

1. 보호구역 지정

1) 보호구역 지정 개요 및 점검 항목

물리적 보호구역 지정 및 각 구역별 적정한 보호대책 수립을 이행해야 함



물리적 보호구역 정의 및 구역별 보호대책 수립 및 이행여부 확인

접견구역	•외부인 접견 구역
제한구역	•사무실 지역 등
통제구역	•주요 정보처리 설비 및 시스템 구역 등 중요시설이 위치해 있는 곳



물리적 보호구역

1. 보호구역 지정

2) 항목별 세부 점검 내용

- 업무의 중요도 및 정보자산 위치에 따른 물리적 보호 구역 구분 및 구역별 보호대책 수립· 이행

① 접근구역

- 외부인이 별다른 출입증 없이 출입 가능 구역
예) 회사의 접근장소 등

② 제한구역

- 비인가된 접근 방지를 위한 별도의 출입통제 장치 및 감시시스템 설치
예) 부서별 사무실 등

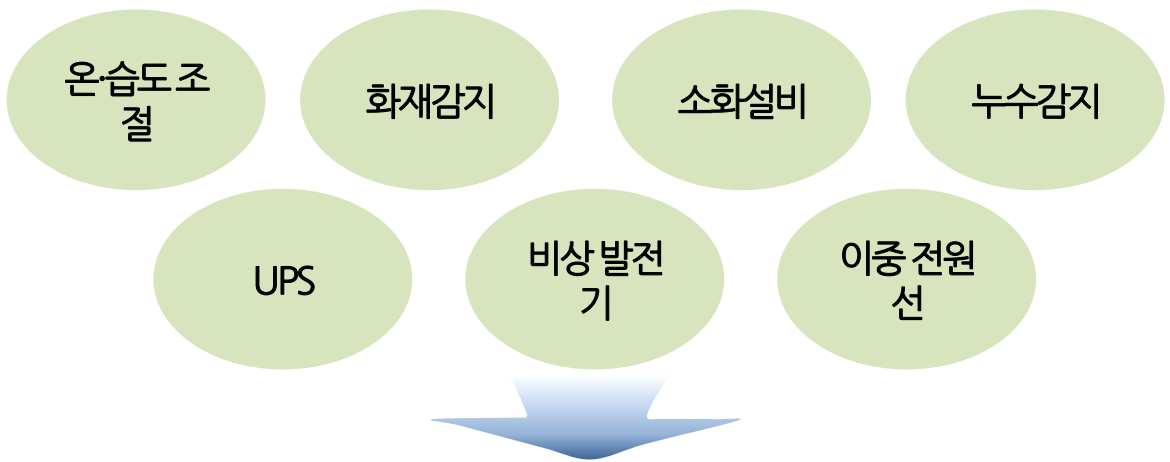
③ 통제구역

- 출입자격을 최소인원으로 유지 및 출입을 위한 추가적인 절차가 필요한 곳
예) 전산실, 통신장비실, 관제실, 공조실, 발전실, 전원실 등
- 통제구역임을 표시하여 접근시도 자체를 원천적으로 차단
- 불법적인 접근시도여부를 주기적으로 검토
- 검토결과에 따른 적절한 조치

2. 보호설비

1) 보호설비 개요

각 보호구역의 중요도 및 특성에 따라 인재 및 재해에 대비



- 보호설비를 안정적으로 구축하여 운영해야 함
- 주요 시스템을 외부 집적정보통신시설에 위탁 운영하는 경우:
관련 요구사항을 계약서에 반영하고 주기적 검토 수행해야 함

2. 보호설비

2) 점검 항목과 내용

- 인재 및 자연재해 등에 대비한 필요한 설비 구비 / 운영절차 수립 및 관리여부 확인

• 필요한 설비

- | | |
|----------------|----------------------|
| - 항온항습기 또는 에어컨 | - 전압유지기 |
| - 화재감지 및 소화설비 | - CCTV |
| - 누수감지기 | - 출입통제시스템과 전력선 이중화 |
| - UPS | - 정보시스템기기의 rack 설치 등 |
| - 비상발전기 | |



“파손방지 대책 수립”

- 전산실의 경우 상기 설비를 갖추고 비상 시 신속한 복구 및 대응이 가능하도록 운영절차를 마련
-
- 보호구역 내 주요 시스템 및 인력 보호를 위한 필요한 설비 설치 및 지속적 운영·관리
-
- 화재감지기를 적절한 간격 설치 및 충분한 용량의 소화기 비치
 - 보호구역 면적에 대비하여 화재 감지기 및 소화기 설치
 - 주기적으로 화재감지기 및 소화기 상태 점검



2. 보호설비

2) 점검 항목과 내용

- 누수를 탐지할 수 있는 설비 설치 및 지속적 운영· 관리
 - 주요 시스템이 위치한 보호구역의 경우 누수 발생 시 탐지가 가능하도록 누수감지기 설치
 - 정상적인 작동유무를 주기적으로 점검
- 안정적인 환경을 위한 항온항습 또는 에어컨 설치 및 운영· 관리
 - 온도 16~26℃, 습도 40~70%를 항상 유지
 - 전산실 규모에 따른 적절한 규모의 항온항습기 또는 에어컨을 설치 및 주기적으로 상태 점검
- 안정적인 전력 공급을 위한 시설 설치 및 지속적 운영· 관리
 - 갑작스러운 전력공급 중단 시 주요 정보시스템이 전력을 안정적으로 공급받을 수 있어야 함
 - 무정전 전원장치(UPS), 비상발전기, 이중전원선, 전압유지기, 접지시설 등 구축 및 주기적 상태 점검
- 임직원이 대피절차에 따른 안전한 대피를 하기 위한 시설 설치
 - 신속한 대피를 위한 비상벨, 비상등, 비상로 안내표지 등의 설비 구축



2. 보호설비

2) 점검 항목과 내용

- 외부 집적정보통신시설(IDC)에 위탁운영의 경우:

환경적 위협과 물리적 위협으로 부터의 보호에 필요한 요구사항 계약서 반영 및 운영상태 주기적 검토

• 주요 항목

- | | |
|---------------|--------------------------|
| - 온·습도 조절기 | - 외부침입감지 및 경보 |
| - 화재감지 및 소화설비 | - 출입통제시스템 |
| - 누수감지기 | - 전력선 이중화 |
| - UPS | - 파손방지 |
| - 비상발전기 | - 구조의 안전성 |
| - 전압유지기 | - IDC의 책임보험 가입여부 등 |
| - CCTV | (미가입 시, 1천만 원 이하 과태료 부과) |



3. 보호구역 내 작업

1) 보호구역 내 작업 개요 및 점검 항목

- 보호구역 내 작업이 필요한 경우 작업신청 및 수행 관련 절차 수립, 작업기록의 주기적 검토

• 점검 항목

- 작업신청 시 관련자 검토 · 승인 필요
(예 : 보호구역 출입통제 담당자, 작업신청부서장 등)
- 작업기록에는 작업일자, 작업시간, 작업목적, 작업내용, 작업업체 및 담당자명, 검토자 및 승인자 등 포함
- 작업 수행을 위한 보호구역 출입 절차 마련 및 출입기록의 주기적 검토 필요
- 작업 수행을 위한 모바일 기기 반·출입 및 모바일 기기 안전성 확보 절차 마련



4. 출입통제

1) 출입통제 개요 및 점검 항목

- 출입통제 : 각 보호구역, 보호구역내 주요 설비 및 시스템에 비인가자의 출입 통제 및 출입 및 접근 이력 주기적 검토
- 각 보호구역별 내·외부자 출입통제 절차 마련 및 출입 가능한 임직원 현황 관리

• 점검항목

- 공식적인 출입절차 마련 및 인가된 사람만 출입할 수 있도록 통제
- 통제구역의 경우, 업무목적에 따라 최소한의 인원만 출입할 수 있도록 통제
- 보호구역에 외부인 출입이 필요한 경우, 내부 임직원 출입절차와는 다른 별도의 절차를 마련하여 출입통제



4. 출입통제

1) 출입통제 개요 및 점검 항목

- 각 보호구역에 대한 내·외부자 출입기록 일정기간 보존 및 출입기록, 출입권한의 주기적 검토

• 점검항목

- 업무 목적에 적합한 출입권한을 부여
- 절차에 따른 출입권한 부여
- 퇴직자 또는 직무 변경자 출입권한 삭제·조정 및 출입증 회수
- 일상 업무시간 이외 출입 시 출입사유 확인
- 중요한 보호구역인 통제구역의 비인가자 출입시도를 확인하여 그 사유를 확인하고 조치
- 유지보수, 비상 시 외부자 출입 적정성 검토
- 조직의 업무특성에 따른 기준을 별도로 마련하여 보호구역 출입 적정성 검토 필요
- 단순 잠금장치(자물쇠)를 사용하는 경우, 반드시 출입대장을 작성하여 출입기록을 확인할 수 있어야 함



4. 출입통제

1) 출입통제 개요 및 점검 항목

- 장비, 업무관련 대외비 이상의 문서, 저장매체(CD, 테이프 등)에 대한 반·출입 관련 정책 및 절차 수립·이행

반·출입관리대장

- ✓ 일시, 품명 및 수량, 반·출입 담당자, 반·출입 장소, 반·출입 사유, 관리부서 확인
- ✓ 서명 및 내용 포함하여 이력관리
- ✓ 관리대장 내용의 적정성을 주기적으로 확인



5. 모바일 기기 반·출입

1) 모바일 기기 반·출입 개요 및 점검 항목

- 보호구역 내 임직원 및 외부자 모바일 기기 반·출입 통제절차 수립 및 기록·관리

• 점검 항목

- 보호구역 출입통제 책임자 사전승인, 반·출입 관리대장 기록, 모바일 기기 보안 점검 수행, 모바일 기기 반·출입내역 주기적 점검 등을 수행
- 모바일 기기 반·출입을 통한 보안사고 예방절차 수립 시 고려해야 할 사항

반입 시	반출 시
•안티바이러스 S/W를 통한 악성코드 감염여부 점검 •USB 포트 차단 및 USB 반입 금지 •모바일 기기에 장착된 카메라 렌즈 봉인 등	•중요 정보 저장 여부 확인 등

- 주요 시설 및 정보자산이 위치한 통제구역 내 모바일 기기 반입은 원칙적으로 금지하는 것이 바람직함
- 업무목적으로 불가피하게 모바일 기기를 사용하여야 하는 경우 사전 승인을 받도록 해야 함



5. 모바일 기기 반·출입

1) 모바일 기기 반·출입 개요 및 점검 항목

- 모바일 기기 반·출입 절차에 따라 반·출입대장 작성 및 모바일 기기 반·출입 이력의 주기적 점검

- 보호구역 내 임직원 혹은 외부자가 업무목적을 위한 모바일 기기를 반·출입하는 경우 반·출입대장에 이력을 기록해야 함

반·출입관리대장

- ✓ 일시, 사용자, 기종(모델), 기기 식별번호(MAC, 시리얼번호 등), 사유, 반·출입 장소, 보안점검 결과, 관리자 확인서명 등
- ✓ 관리자의 주기적 점검 및 반·출입 적정성 검토

1. 케이블 보안

1) 케이블 보안 개요 및 점검 항목

- 전력 및 통신케이블은 외부로부터 받는 물리적 손상이나 전기적 영향으로부터 보호

[점검항목]

- 전력 및 통신케이블은 물리적으로 구분하여 배선
- 전력 및 통신케이블에 대한 식별
- 전력 및 통신케이블 사이의 상호간섭을 방지하기 위한 거리유지
- 케이블을 지지하고 보호할 수 있는 설비 설치
- 도청이나 손상이 일어나지 않도록 케이블을 보이지 않게 매설
- 약전실, 강전실, 배전반 등에 대한 접근통제 등

2. 시스템 배치 및 관리

1) 시스템 배치 및 관리 개요와 점검 항목

- 정보시스템의 특성을 고려한 배치 장소의 분리 여부

[점검항목]

- 정보시스템 특성에 따라 분리하여 배치하고 전산 랙(Rack)등을 이용하여 시스템을 외부로부터 보호
- 중요 정보를 저장하고 있는 서버나 중요 네트워크 장비의 경우, 인가된 자에 한해 접근이 가능하도록 관리

- 정보시스템의 실제 물리적 위치를 손쉽게 확인할 수 있는 방안 마련

[점검항목]

- 시스템 정보자산목록에 물리적 위치 항목을 포함하여 목록에서 언제든지 물리적 배치를 확인 가능하도록 관리
- 목록을 최신본으로 관리

사무실 보안

1. 개인업무 환경 보안

1) 개인업무 환경 보안 개요

- 개인업무 환경 보안은 일정시간 동안 자리를 비울 경우에 책상 위에 중요한 문서나 저장매체를 남겨놓지 않고 컴퓨터 화면에 중요 정보가 노출되지 않도록 화면보호기 설정 및 패스워드 노출 금지 등 보호대책을 수립하는 것을 의미

1. 개인업무 환경 보안

2) 점검 항목

[개인업무 환경에서의 정보보호 정책]

- ① 일정시간 자리 이석, 퇴근, 휴가 시 책상 위에 중요 문서, 저장매체 등 방치 금지
- ② 중요 문서가 보관된 서랍장, 캐비닛은 잠금장치 사용
- ③ 일정시간 컴퓨터 미사용 시 화면보호기 설정, 재시작 시 로그인 설정, 장기간 자리 이석 시 로그오프
- ④ 안전한 로그인 비밀번호 사용 및 주기적 변경
- ⑤ 개인용컴퓨터 백신 및 최신 패치 설치, 공유폴더 설정 제한
- ⑥ 개인용컴퓨터 및 업무시스템의 안전한 로그인 비밀번호 사용 및 주기적 변경, 로그인 정보(ID, 비밀번호) 노출 금지 (포스트잇 기록 부착 등)
- ⑦ 중요 정보가 포함된 문서 폐기 시 세절기를 이용한 파쇄 등

[개인업무 환경에서 정보보호 준수여부의 주기적 점검]

- ① 정보보호 준수여부를 자가진단하고, 관리부서에서는 주기적 점검
- ② 개인업무 환경보안 미준수자는 상벌규정에 따라 관리 수행

2. 공용업무 환경 보안

1) 공용업무 환경 보안 개요

- 공용업무 환경 보안은 사무실에서 공용으로 사용하는 사무처리 기기, 문서고, 공용 PC, 파일서버 등을 통해 중요 정보 유출이 발생하지 않도록 보호대책을 마련하는 것을 의미

2. 공용업무 환경 보안

2) 점검 항목

[공용업무 환경에서의 정보보호 정책]

- ① 공용사무기기 주변에 중요 정보문서 방치 금지
- ② 공용 PC 사용 시 화면보호기 설정, 로그인 암호 설정, 주기적 패스워드 변경, 중요 정보 저장 제한
- ③ 파일서버 접근권한은 부서별로 부여하여 불필요한 정보공개 최소화
- ④ 문서고 접근권한은 부서별 혹은 업무별로 부여하여 출입 가능인원 최소화
- ⑤ CCTV 혹은 출입통제시스템을 설치하여 출입이력 관리
- ⑥ 공용사무실 내 중요 정보 문서 방치 금지
- ⑦ 기타 공용업무 환경에 대한 보안대책 수립

[관리자 지정 및 준수여부의 주기적 검토 여부]

- ① 미준수 사항 발견 시, 관련 내용을 임직원에게 공고 또는 교육을 수행하여 주의 환기를 통한 재발방지 유도

핵심요약

1. 물리적 보호구역

1) 보호구역 지정

- 비인가자의 물리적 접근 및 각종 물리적, 환경적 재난으로부터 주요 설비 및 시스템을 보호하기 위하여 통제구역, 제한구역, 접근구역 등 물리적 보호구역을 지정하고 각 구역별 보호대책을 수립·이행해야 함

2) 보호설비

- 각 보호구역의 중요도 및 특성에 따라 화재, 전력이상 등 재해에 대비하여 온도 및 습도 조절, 화재감지, 소화설비, 누수감지, UPS, 비상발전기, 이중전원선 등의 설비를 충분히 갖추고 운영절차를 수립하여 운영해야 함

3) 보호구역 내 작업

- 유지보수 등 주요 설비 및 시스템이 위치한 보호구역 내에서의 작업 절차를 수립하고 작업에 대한 기록을 주기적으로 검토해야 함

핵심요약

1. 물리적 보호구역

4) 출입통제

- 보호구역 및 보호구역 내 주요 설비 및 시스템은 인가된 사람만이 접근할 수 있도록 출입을 통제하고 책임 추적성을 확보할 수 있도록 출입 및 접근 이력을 주기적으로 검토해야 함

5) 모바일 기기 반·출입

- 노트북 등 모바일 기기 미승인 반·출입을 통한 중요 정보 유출, 내부망 악성코드 감염 등의 보안사고 예방을 위하여 보호구역 내 임직원 및 외부자 모바일 기기 반·출입 통제절차를 수립하고 기록·관리해야 함

핵심요약

2. 시스템 보호

1) 케이블 보안

- 데이터를 송수신하는 통신케이블이나 전력을 공급하는 전력 케이블은 손상을 입지 않도록 보호

2) 시스템 배치 및 관리

- 시스템은 그 특성에 따라 분리하여 배치하고 장애 또는 보안사고 발생 시 주요 시스템의 위치를 즉시 확인할 수 있는 체계를 수립해야 함

3. 사무실 보안

1) 개인업무 환경 보안

- 일정시간 동안 자리를 비울 경우에는 책상 위에 중요한 문서나 저장매체를 남겨놓지 않고 컴퓨터 화면에 중요 정보가 노출되지 않도록 화면보호기 설정, 패스워드 노출 금지 등 보호대책을 수립해야 함

2) 공용업무 환경 보안

- 사무실에서 공용으로 사용하는 사무처리 기기, 문서고, 공용 PC, 파일서버 등을 통해 중요 정보 유출이 발생하지 않도록 보호대책을 마련해야 함